

IMPACT ANALYSIS

CR-020: Student able change their password

1. Change Summary

CR-020 introduces Student able change their password in the Student's dashboard.

Students will be able to change their password. After change student will be got on the notify message.

2. Impact Assessment

Area	Impact	Assessment
Frontend	Low - Moderate	Change Password logic and UI will be added.
Backend	Moderate	Password hash, password change functions are will implement.
API	Low	Add PATCH <code>/api/students/:id</code> in use.
Database	None	No schema or data changes required.
Authentication	None	Existing authentication remains unchanged.
Authorization	None	Existing administrator protection remains unchanged.
Performance	None	Existing performed.
CRUD	Low	Edit must continue using correct <code>student_id</code> .
Deployment	None	No database migration or new backend endpoint required.

3. Frontend Impact

The main affected area is the Student dashboard.

Potential changes include:

- Change password.
- Password, Re-enter password fields.
- Change, Clear buttons.
- Clear Search functionality.
- Result message.
- Responsive styling.

3. Backend, API and Database Impact

The main affected area is the studentRoutes, studentController and studentModel.

The new API endpoint:

PATCH /api/students/:id

endpoint will give permission for change password.

New API endpoint PATCH /api/students/:id .

No database schema or data changes are required.

4. Security Impact

The existing authentication and authorization mechanisms remain unchanged.

The student password change time be accessible only to authorized student.

The feature must:

- Not bypass existing authorization.
- Not expose additional sensitive information.
- Use normal React rendering.
- Preserve existing backend security controls.

5. CRUD and Functional Impact

Existing administrator CRUD operations must continue to work after filtering.

Particular attention is required for:

- Editing a student password.

6. Performance Impact

The expected performance impact is low because change password simple low perform task.

7. Testing Impact

Manual testing should cover:

- Password, Re-enter password values are matching time only password want to change.
- Properly show error, success messages.
- Clear button function wants clear Password, Re-enter password values and auto focus Password.
- Change button function is wanted to change password.
- New password wants to store in database as encrypt.

8. Risk Analysis

Risk	Impact	Mitigation
A password change may not invalidate existing login tokens	High	Decide whether password changes should revoke existing sessions. If required, implement token/session revocation; otherwise document that existing tokens remain valid until expiry.
Passwords could be exposed if stored or transmitted incorrectly.	High	Send requests over HTTPS, hash new passwords with bcrypt, and never log or return passwords or password hashes.
Responsive UI problems	Low	Test supported screen sizes.

9. Overall Impact and Recommendation

Overall Impact: Medium

CR-020 is primarily frontend, backend change. It does not require database, authentication, or authorization changes.

The change is technically feasible and recommended for implementation, subject to formal approval and subsequent testing.

Key implementation consideration:

- Protect the password-change endpoint with authentication and use the authenticated user ID (req.user.userId) so students can change only their own password.
- Require the current password and verify it against the stored hash with bcrypt before accepting a change.
- Validate the new password and confirmation on both the frontend and backend.
- Hash the new password with bcrypt before updating the users.password_hash field. Never return or log passwords or hashes.
- Show clear success and error messages, and clear the password fields after a successful change.
- Decide whether existing login sessions should be invalidated after a password change. The current JWT setup does not automatically revoke tokens.
- Test successful changes, incorrect current passwords, invalid inputs, unauthenticated requests, and signing in with the new password.